

AWS Cloud Security Lab

Hoja de Referencia Técnica · Detección y Mitigación de 4 Puntos Ciegos

SEGURIDAD PRÁCTICA & COMPLIANCE

01 IAM: Principio de Menor Privilegio

El Riesgo: Conceder permisos con comodines globales (s3:* en Resource: *) permite exfiltración y borrado destructivo si la instancia es vulnerada.

- Nunca uses políticas administradas globales como AdministratorAccess en roles de servicio.
- Restringe las acciones al verbo estricto necesario (ej. s3:PutObject).
- Acota el recurso al ARN exacto del prefijo del bucket (arn:aws:s3:::bucket/galeria/.*).

```
"Action": ["s3:PutObject"],
"Resource": "arn:aws:s3:::cloudsec-
demo/galeria/*"
```

02 Perímetro de Red: SG vs. NACL

El Riesgo: Abrir puertos de gestión (SSH/RDP) o servicios a 0.0.0.0/0 expone los workloads a escaneos automatizados y fuerza bruta.

- **Security Groups:** Son *stateful* (con estado) y operan a nivel de interfaz de red (ENI). Solo permiten reglas de ALLOW.
- **Network ACLs:** Son *stateless* (sin estado) y operan a nivel de subred. Permiten reglas explícitas de DENY para bloquear IPs atacantes antes de llegar a la instancia.
- Sustituye SSH público por **AWS Systems Manager Session Manager** (\$0 USD).

03 Amazon S3: Block Public Access & STS

El Riesgo: Hacer buckets públicos para permitir descargas de clientes viola regulaciones (ISO 27001, SOC 2) y genera riesgo de fuga de datos masiva.

- Activa **S3 Block Public Access (BPA)** en los 4 niveles a nivel de cuenta y bucket.
- Para descargas seguras, genera **URLs prefirmadas temporales** firmadas con SigV4 vía AWS STS.
- Las URLs expiran automáticamente (ej. 15 minutos) sin necesidad de abrir el bucket a internet.

```
s3.generate_presigned_url('get_object',
    Params={'Bucket': b, 'Key': k}, ExpiresIn=900)
```

04 Trazabilidad Forense: AWS CloudTrail

El Riesgo: Modificaciones no autorizadas en reglas de red o roles IAM pasan desapercibidas sin un registro inmutable de auditoría.

- **Event History:** Registra gratis los últimos 90 días de llamadas a la API de gestión.
- Identifica al actor: ARN del usuario o rol asumiendo la llamada.
- Registra la IP de origen, el User-Agent y los parámetros exactos (ej. AuthorizeSecurityGroupIngress).
- Esencial para responder a incidentes y auditorías SOC 1/2 e ISO 27001.

Gobernanza y Destrucción a \$0 USD Residuales: Todo laboratorio práctico debe contar con un ciclo de vida limpio. Una vez concluidas las pruebas de validación, ejecuta `cdk destroy` para eliminar buckets, roles, security groups y la VPC, garantizando cero costos posteriores.